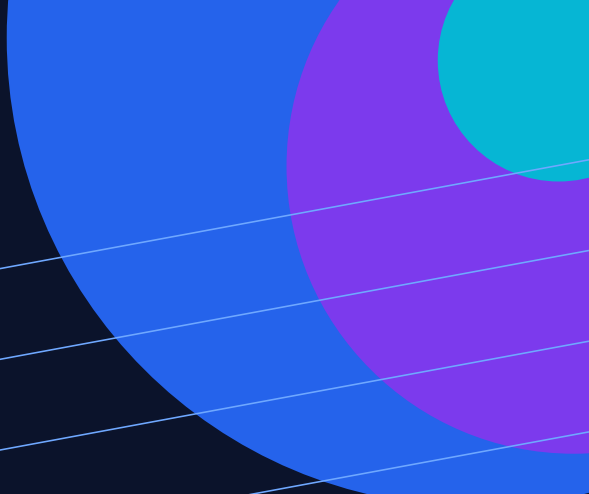




THREAT RESEARCH / DETECTION ENGINEERING

Starland RAT Python Loader Masquerading

pythonw.exe executes a compiled loader disguised as LICENSE.txt

REPORT	STATUS	CONFIDENCE
Threat-hunting dossier	Hunting query	High

Prepared for defensive research and environment-specific validation. Source facts, analytical interpretation, assumptions and proposed detection logic are intentionally separated.

VERSION 1.0 / 22 JULY 2026

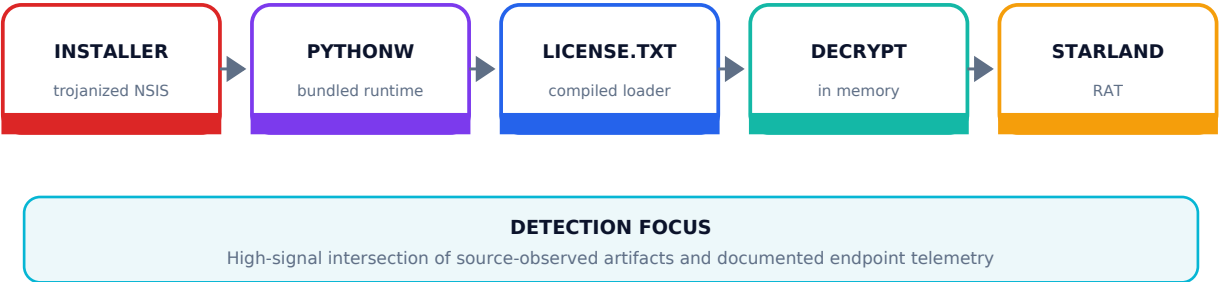
Executive Assessment

WHY THIS MATTERS

Cisco Talos analyzed trojanized installers bundling pythonw.exe and a compiled Python loader named LICENSE.txt. The runtime-plus-masqueraded-filename intersection is simple and potentially low-volume, but the filename is trivially changed.

Dimension	Assessment	Operational Implication
Observed behavior	A trojanized NSIS installer executes LICENSE.txt through pythonw.exe; the loader decrypts and runs Starland RAT in memory.	A text-extension argument to pythonw.exe is an efficient campaign pivot.
Detection posture	Hunting query	Hunt first; promote only if legitimate packaging does not generate the same pattern.
Telemetry	Microsoft Defender XDR DeviceProcessEvents	Runtime, command line, path, parent and hash are available in one event.
Primary limitation	The filename is mutable and the installer may wrap execution.	Absence of a hit does not exclude Starland or UAT-11795 activity.

Attack and observation flow



Evidence Model

Evidence class	Statement	Use in the package
Source fact	Talos reports bundled pythonw.exe executing a compiled Python loader masquerading as LICENSE.txt, followed by in-memory Starland RAT execution.	Directly supports the selected behavior or artifact.
Documented telemetry	DeviceProcessEvents exposes process image, folder, command line, initiating process, account/device identifiers and hashes.	Supports the table, fields and investigation pivots.
Analytical interpretation	pythonw.exe receiving LICENSE.txt as an argument should be uncommon, but rarity must be measured in each environment.	Defines why the intersection may be distinguishable.
Unvalidated assumption	The loader filename appears in ProcessCommandLine and is not hidden by a wrapper.	Must be measured before deployment or promotion.

**EVIDENCE
BOUNDARY**

The hunt does not prove that the referenced file contains Python bytecode, that it decrypts Starland, or that initial access was ClickFix. File retrieval and parent analysis remain mandatory.

Telemetry contract

Component	Requirement	Failure condition
Data source	Microsoft Defender XDR DeviceProcessEvents	Process telemetry unavailable.
Core fields	Timestamp, DeviceId, DeviceName, FileName, FolderPath, ProcessCommandLine, AccountName, initiating-process fields, SHA1, ReportId	Arguments absent or runtime execution mediated by another process.
Time context	30-90 day historical hunt.	Retention does not cover the campaign or installer execution.

Detection Logic

HYPOTHESIS

A matching installer execution should show pythonw.exe with LICENSE.txt in the command line, ideally with an installer or NSIS-related parent and an unusual runtime path.

```
DeviceProcessEvents
| where FileName =~ "pythonw.exe"
| where ProcessCommandLine contains "LICENSE.txt"
| project Timestamp, DeviceId, DeviceName, AccountName,
    FolderPath, ProcessCommandLine,
    InitiatingProcessFileName,
    InitiatingProcessCommandLine, SHA1, ReportId
```

Condition	Purpose	Durability
pythonw.exe	Selects the GUI Python runtime reported by Talos.	Medium
LICENSE.txt	Matches the loader masquerading artifact.	Low durability

Analyst Triage

Priority	Question	Evidence to collect
1	Where is pythonw.exe located and signed?	Runtime path, hash, signer and prevalence.
2	What is LICENSE.txt really?	File bytes, magic, hash, creation source and entropy.
3	What launched the runtime?	Installer parent, NSIS artifacts and user context.
4	What followed?	Memory detections, child processes, persistence and outbound traffic.

False-positive model

Scenario	Why it may match	Recommended handling
Python packaging	An application may ship scripts or resources with nonstandard extensions.	Validate publisher, product owner and runtime path.
Software testing	Developers may deliberately execute extensionless or .txt content.	Confirm device role and repository/build context.
Security research	Analysts may reproduce the campaign artifact.	Confirm authorized sandbox or lab activity.

NO PREMATURE ALLOWLISTING

Do not exclude pythonw.exe globally. Any exception should include owned software, verified publisher/path and a stable parent or package identifier.

Validation Plan

Step	Action	Expected evidence
1	Run 30-90 days.	Distinct parent/path/command combinations.
2	Retrieve each referenced file.	Actual format, signer/hash and origin.
3	Identify software ownership.	Benign product or unexplained installation.
4	Assess artifact durability.	Whether a broader masquerading hunt is supportable.

Decision	Criterion
Promote / retain	Very low prevalence with explainable benigns or suspicious installer ancestry.
Tune	Add runtime path, parent or unsigned-file context only after evidence.
Reject	Legitimate applications frequently execute LICENSE.txt through pythonw.exe.

OPERATING NOTE

The report labels ClickFix initial access as unconfirmed because Talos presents it as a possibility rather than a directly established fact for every infection.

ATT&CK; Mapping & References

Technique	Relationship	Mapping posture
T1059.006 - Python	Python runtime executes the loader.	Direct behavior.
T1036.008 - Masquerade File Type	Compiled loader is disguised with a .txt filename.	Direct behavior.

Primary and authoritative references

- 1. Cisco Talos - UAT-11795 deploys novel Starland RAT and WLDR
<https://blog.talosintelligence.com/uat-11795-deploys-novel-starland-rat-and-bespoke-wldr-c2-implant-in-financially-motivated-campaign/>
- 2. Microsoft Learn - DeviceProcessEvents schema
<https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>

DOCUMENT STATUS

Research-derived and unvalidated in the target environment. The package is suitable for controlled testing and analyst review; it is not evidence that a specific environment is compromised.